



Information Security Risk Assessment Procedure

Document No	TCH-CYB-W005	Information Classification	Internal ▾
Document Author/s	Royette Miranda	Document Type	Department Procedure
Document Owner	Systems & Infrastructure Security		

1. Purpose and Objective

This procedural document provides the standard instructions for completing the Information Security Risk Assessment [\(ISRA\) Template](#). It is intended to ensure that information security risks are identified, assessed, treated, documented, reviewed, and reported in a consistent and evidence-based manner. The procedure supports PDAX in evaluating risks affecting the confidentiality, integrity, and availability of information assets, systems, applications, processes, infrastructure, and third-party services. It also provides guidance on the use of the 5x5 likelihood and impact rating methodology, control effectiveness assessment, residual risk calculation, and documentation of risk treatment actions.

2. Scope

This procedure applies to all information security risk assessments conducted using the ISRA Template, including assessments covering:

- New systems, applications, business processes, infrastructure components, or technology environments, and material changes to existing ones, including every proposed initiative requiring the submission and approval of a Product Requirements Document (PRD), prior to implementation or deployment;
- New or changed third-party services, outsourced technology arrangements, or vendor-managed platforms whose services involve process, store, transmit, or have access to Company or customer data;
- P1 and P2 Security incidents or suspected compromise events;
- Audit findings, regulatory findings, vulnerability assessment results, penetration testing results, or control deficiencies;
- Management, compliance, risk, audit, or regulatory requests requiring formal risk assessment.
- Changes to how the business stores, processes, transmits, or supports Company or customer information.

3. Roles and Responsibilities

Role / Unit	Responsibilities
Cybersecurity Team	Facilitates the ISRA process; validates risk descriptions, likelihood and impact ratings, control effectiveness, residual risk results, and risk treatment recommendations; maintains the ISRA Template and rating methodology.
Risk Owner / Process Owner	Provides process, system, and operational context; confirms the accuracy of identified risks; owns the decision to treat, accept, transfer, or avoid the risk within the approved governance process.
Control Owner	Provides details and evidence of existing controls; confirms whether controls are designed, implemented, and operating effectively. The Process Owner shall generally be assigned as the Control Owner for controls embedded within or dependent on the business process, including operational, procedural, and business-owned controls. The Cybersecurity Team shall be assigned as the Control Owner where the control is directly managed, operated, or maintained by Cybersecurity, such as security monitoring, vulnerability management, security tooling, access security controls, or other cybersecurity-specific controls.
Action Owner	Implements agreed remediation or enhancement actions; provides target commitment dates and status updates until closure. The Process Owner shall generally be

Information Security Risk Assessment Procedure TCH-CYB-W005

	assigned as the Action Owner where the remediation requires changes to the business process, procedure, application usage, documentation, or other activities under the Process Owner's authority. The Cybersecurity Team shall be assigned as the Action Owner where the remediation requires implementation or enhancement of cybersecurity-owned controls, security configurations, security tools, monitoring capabilities, or other activities directly managed by Cybersecurity.
Head of DevSecOps	Reviews and approves completed assessments, risk treatment decisions, and formal risk acceptance when residual risk remains outside the acceptable threshold.

4. Periodic Review

This procedure and the ISRA Template shall be reviewed at least annually by the Information Security Team, or earlier when there are material changes to regulatory requirements, risk methodology, systems, processes, threat landscape, or management direction. Completed risk assessments shall be reviewed at least annually or when any of the following occurs:

- New systems, applications, business processes, infrastructure components, or technology environments, and material changes to existing ones, including every proposed initiative requiring the submission and approval of a Product Requirements Document (PRD), prior to implementation or deployment;
- New or changed third-party services, outsourced technology arrangements, or vendor-managed platforms whose services involve process, store, transmit, or have access to Company or customer data;
- P1 and P2 Security incidents or suspected compromise events;
- Audit findings, regulatory findings, vulnerability assessment results, penetration testing results, or control deficiencies;
- Management, compliance, risk, audit, or regulatory requests requiring formal risk assessment.

Information Security Risk Assessment Procedure TCH-CYB-W005

- Changes to how the business stores, processes, transmits, or supports Company or customer information.

5. Definitions of Terms

Term	Definition
Information Security Risk	The possibility that a threat may exploit a vulnerability and adversely affect the confidentiality, integrity, or availability of information assets.
Security Event	A potential event or action that may cause harm to systems, data, processes, or technology services.
Vulnerability	A weakness that may reduce a system's information assurance and may affect confidentiality, integrity, or availability through unauthorized data access, unauthorized data modification, or disruption of authorized access.
Inherent Risk	The level of risk before considering the effect of existing controls.
Existing Controls	Implemented safeguards, processes, tools, approvals, monitoring activities, or technical measures that reduce risk likelihood or impact.
Control Effectiveness	The degree to which existing controls reduce the inherent risk exposure, based on whether such controls are designed, implemented, consistently operating, evidenced, tested, and effective.
Residual Risk	The remaining risk after considering existing controls and their effectiveness.
Risk Treatment	The selected response to the residual risk, such as Treat, Accept, Transfer, or Avoid.
Risk Owner	The individual or unit accountable for the risk and for ensuring that the treatment decision is appropriate.

Information Security Risk Assessment Procedure TCH-CYB-W005

Action Owner	The individual or unit accountable for completing an agreed remediation or improvement action.
--------------	--

6. Procedure Guide

6.1 End-to-end ISRA Process

The Information Security Team shall conduct the ISRA in coordination with the Process Owner. The Process Owner shall provide the business, operational, and technical information necessary to support the assessment, while the Information Security Team shall facilitate the assessment, evaluate the identified information security risks, and document the results. The Information Security Team shall ensure the following process shall be followed:

Step	Process Activity	Action Owner	Description / Expected Action
1	Identify and Validate Risk Scenarios	Cybersecurity Team and Risk Owner / Process Owner	Identify threat events, vulnerabilities, control gaps, and risk scenarios. Draft and validate risk descriptions using a clear format that identifies the threat event, affected asset or process, and potential impact.
2	Assess Inherent Risk	Cybersecurity Team	Assess the inherent likelihood and inherent impact before considering existing controls, using the rating guidance in the ISRA Template.
3	Identify and Assess Existing Controls	Control Owner	Identify implemented controls that reduce the likelihood or impact of the risk. Assess the design and operating effectiveness of these controls based on evidence, consistency, implementation, and effectiveness.
4	Determine Residual Risk and Treatment Option	Cybersecurity Team	Calculate and validate the inherent and residual risk scores. Determine the proposed risk treatment option, such as Mitigate, Accept, Transfer, or Avoid, based on the residual risk result and applicable governance requirements.
5	Develop and	Action Owner/Process Owner	Develop the risk treatment or remediation

Information Security Risk Assessment Procedure TCH-CYB-W005

	Assign Treatment Actions		plan, assign action owners, and set commitment dates for required remediation, control enhancement, risk acceptance, transfer, or avoidance actions.
6	Review and Approve the ISRA	Head of DevSecOps	Review the completed ISRA for accuracy and completeness. Obtain approval for risk treatment decisions and formal risk acceptance, where applicable, from the appropriate approving authority.
7	Monitor, Validate, and Close Actions	Cybersecurity Team	Monitor remediation progress and overdue actions. Validate completion and effectiveness of remediation or control enhancement actions before closing completed treatment items.
8	Escalate, Report, Maintain, and Reassess	Cybersecurity Team	Escalate high or critical residual risks, overdue remediation, disputed ratings, or risk acceptance outside normal appetite. Report ISRA results to governance bodies, maintain completed records and methodology, and perform periodic reassessment of identified risks.

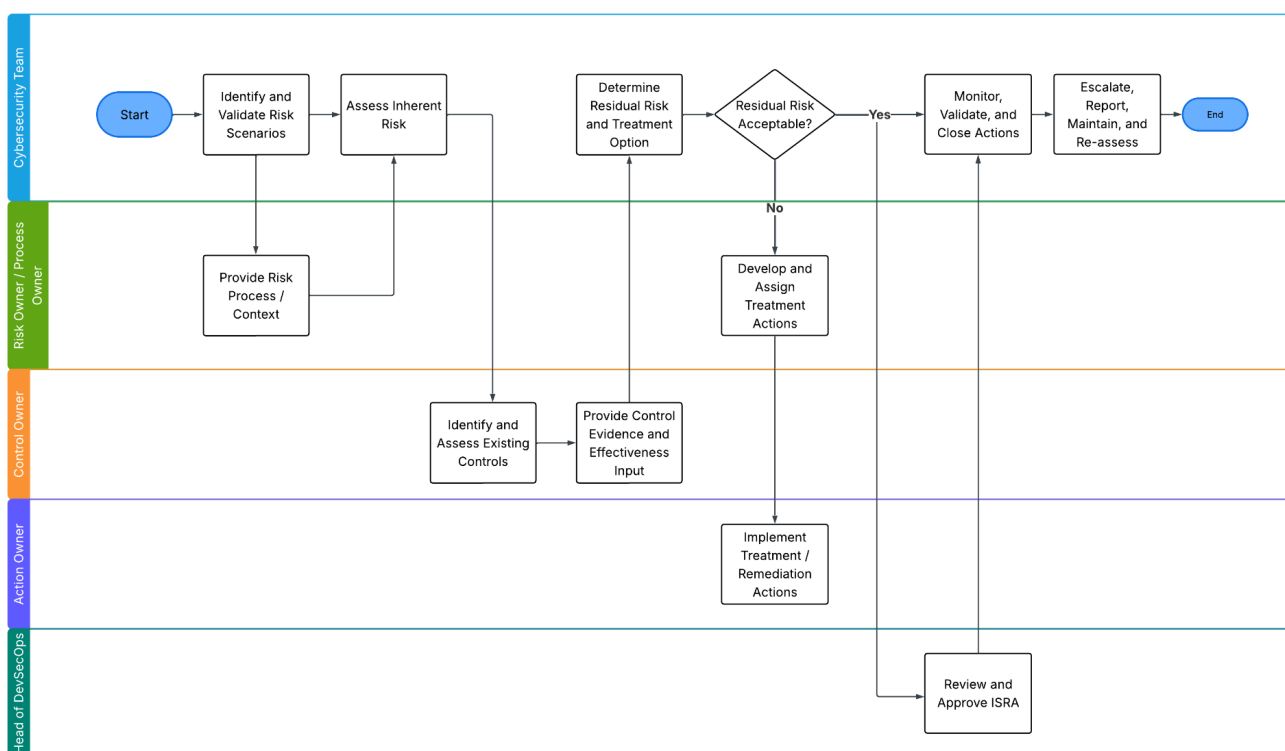


Illustration 1. ISRA Process in diagram format

6.2 Template Overview

The ISRA Template contains the following worksheets:

Worksheet	Purpose
Risk Matrix & Summary	Displays the 5x5 likelihood and impact matrix used to determine the overall risk exposure. The basic scoring approach is Risk Score = Likelihood x Impact.
Rating Guidance	Provides the definitions and thresholds for assigning likelihood and impact ratings from 1 to 5. This sheet must be used as the reference when scoring risks.
Risk Register	The main working sheet where each identified risk is documented, scored, assessed against existing controls, assigned a residual score, and given a treatment decision and action plan.

6.3 General Completion Rules

- Use one row for each distinct risk. Do not combine multiple unrelated risks into a single row.
- Use clear, specific, and complete risk descriptions that identify the threat event, affected asset or process, and possible consequence.
- Use the Rating Guidance worksheet before assigning likelihood and impact scores.
- Base ratings on available evidence, historical incidents, known vulnerabilities, exposure, control gaps, or reasonable expert judgment.
- Document only implemented controls in the Existing Controls column. Planned controls must be placed in the Action Plan / Owner column until implemented.
- Do not overwrite formula-driven fields, including Inherent Risk Score and Residual Risk Score.
- For risks marked as Mitigate, provide a specific action plan, action owner, and commitment date.
- For risks marked as Accept, ensure that the approval is obtained from the appropriate approving authority and retained as supporting evidence.

Information Security Risk Assessment Procedure TCH-CYB-W005

6.4 ISRA Template Completion Procedure

Complete the Risk Register worksheet using the instructions below.

Column	Instruction
ID	Assign a unique reference number to each risk, such as R-01, R-02, and R-03. Do not reuse an ID for a different risk.
Process	Identify the business process, system, application, technology service, or activity where the risk exists. Examples include Cloud Storage, User Access Management, Change Management, Endpoint Security, Vendor Management, Backup and Recovery, and Incident Response.
Risk Description	Describe the risk event clearly using the format: threat event + affected asset/process + potential impact. Example: Risk of inability to restore critical systems during a security incident due to ransomware encryption of backup files, resulting in prolonged operational downtime and potential permanent data loss. Risk of.. Due to.. Resulting in...
Inherent Likelihood (1–5)	Enter the likelihood rating before considering the effect of existing controls. Refer to the Rating Guidance worksheet. Consider incident history, exposure, threat capability, known vulnerabilities, and process frequency.
Inherent Impact (1–5)	Enter the impact rating before considering the effect of existing controls. Refer to the Rating Guidance worksheet. Consider effects on confidentiality, integrity, availability, compliance, customers, operations, financial loss, and reputation.

Information Security Risk Assessment Procedure TCH-CYB-W005

Column	Instruction
Inherent Risk Score	This is formula-driven and should calculate automatically as Inherent Likelihood x Inherent Impact. Do not manually overwrite the formula.
Existing Controls	List current and implemented controls that reduce the likelihood or impact of the risk. Controls should be specific, such as MFA, RBAC, SIEM alerting, immutable backups, access review, encryption, EDR, change approvals, or monitoring.
Control Effectiveness (0–100%)	Enter the estimated effectiveness of existing controls as a percentage. The rating should reflect whether controls are documented, implemented, consistently operating, evidenced, tested, and effective.
Residual Risk Score	This is formula-driven and should calculate automatically as Inherent Risk Score x (1 – Control Effectiveness). Do not manually overwrite the formula.
Risk Treatment	Select the appropriate treatment decision: Treat, Accept, Transfer, or Avoid. Treat should be used when additional remediation is required. Accept should require appropriate approval.
Action Plan / Owner	Document the remediation or improvement action and the accountable owner. The action must be specific and measurable. Example: Security Team to audit immutable backup configuration and validate backup restoration testing results.
Commitment Date	Indicate the target completion date for the action plan. The date should be realistic and aligned with the severity of the residual risk.

6.5 Likelihood Rating Guide

Rating	Category	When to Use
5	Frequent	Risk event occurs regularly – Monthly Activity or operations wherein PDAX is exposed to such risk monthly. For IT, the threat-source is highly motivated and sufficiently capable and controls in place are ineffective or there are no controls at all to prevent the vulnerability from being exercised Function or activity is manually driven. There is no system or application being used in support of function to ensure accuracy of data, information and/ or reports. There is a high level of propensity to error in the execution of function.
4	Likely	Risk event occurs regularly – Quarterly Activity or operations wherein PDAX is exposed to such risk on a quarterly basis The threat-source is motivated and capable, and controls to prevent the vulnerability from being exercised are weak or inadequate i.e., requiring major improvements Function or activity has systems/ application dependencies but is mostly supported by manual processes making it prone to error.
3	Possible	The risk event has occurred in the past YEAR. Activity or operations wherein PDAX is exposed to such risk occurred in the past year

Information Security Risk Assessment Procedure TCH-CYB-W005

Rating	Category	When to Use
		The threat-source is motivated and capable, and controls to prevent the vulnerability from being exercised are weak or inadequate i.e., requiring some improvements Function or activity is supported by systems or applications and reinforced by an appropriate number of manual processes in completing the operation.
2	Unlikely	Risk event has occurred more than a YEAR ago. Activity or operations wherein the PDAX is exposed to such risk has occurred for more than a year ago The threat-source lacks motivation or capability, or controls in place are satisfactory to significantly impede the vulnerability from being exercised. There is minimal manual intervention for function and activity that is mainly supported by systems and applications punctuated by control processes.
1	Rare	Possible to occur but unlikely (no known history of occurrence) The threat-source lacks motivation or capability or controls in place are satisfactory to significantly impede the vulnerability from being exercised Function or activity is systems driven or run by reliable and dependable applications resulting in a very small margin for error coupled by very limited manual intervention.

6.6 Impact Rating Guide

Rating	Impact	When to Use
5	Critical	a. Unauthorized access of Restricted Data (PII/SPI) triggering immediate, mandatory regulatory penalties, legal exposure, and systemic loss of customer trust. b. Permanent loss, ransomware encryption, or corruption of Ledgers, Customer Data, Asset Balances, or Cognito User Groups with no immediate path to recovery. c. Complete inaccessibility of critical core infrastructure (AWS/Fireblocks, MAP, Admin Portals) for 2 hours or more d. Customer-facing platforms with unplanned outage of core functions for 2 hours or more. e. Compromise of AWS root system credentials allowing malicious access or control over sensitive core infrastructure.
4	Major	a. Unauthorized access to internal-use business strategy, intellectual property, or sensitive Audit Trails that gives competitors a severe advantage b. Widespread modification or corruption of data, requiring significant, costly cross-functional manual effort and forensic audits to verify and restore. c. Unplanned full system downtime affecting customers of over an hour but less than 2 hours, requiring formal public/client containment communication. d. Potential or actual compromise of broad user credentials requiring mass rotations and security incident response.
3	Moderate	a. Unauthorized access to internal operational documents (SOPs, Handbooks, policies) that would be valuable to competitors but does not involve client data causes zero harm or exposure to clients.

Information Security Risk Assessment Procedure TCH-CYB-W005

Rating	Impact	When to Use
		b. Detected, non-automated data discrepancies in non-financial records that does not involve client data (e.g., seating charts, attendance logs) that require team-level remediation but do not halt business. c. Support services or internal chat apps (Slack, Freshdesk) offline for eight (8) hours, causing internal operational friction but manageable via temporary manual workarounds provided that customer support channels are not completely unavailable or alternative customer support workarounds remain available. d. Unintentional disclosure of internal non-PII data that requires an internal compliance investigation but not reasonably expected to trigger regulatory notification is strictly not reportable to regulators. e. Unplanned full system downtime affecting customers of less than one hour.
2	Minor	a. Unauthorized access to low-risk internal reference data (system names, office codes) that poses a low-level reconnaissance risk but no immediate threat vector and does not involve client data, personal data, sensitive commercial information, critical business operations data, credentials, or security-sensitive system information. b. Inaccuracies in internal reporting or metadata that cause minor operation interruption but readily resolvable through routine corrective action and result in no customer or financial loss, or significant operational disruption. c. Loss of redundant or secondary systems while primary production services remain fully functional and unaffected. d. Misdelivery of emails where minor, non-sensitive internal information is accidentally sent to the wrong recipient and does not trigger regulatory reporting obligation.

Information Security Risk Assessment Procedure TCH-CYB-W005

Rating	Impact	When to Use
		e. Misclassification of internal data that requires corrective action and does not result in unauthorized third-party disclosure
1	Incidental	a. Unauthorized disclosure of non-confidential, non-personal, and publicly available general data (e.g. an already published marketing announcement mistakenly sent to unintended recipients, a public FAQ shared outside intended channels) b. Negligible data discrepancies that do not affect the accuracy of business records or standard operational flows. c. Brief blips or outages in internal tools (less than 15 minutes) that auto-recover or are quickly resolved with zero data loss. d. Deviation from security measures or controls by internal personnel that does not result in access or disclosure of Company data and no material impact to internal operations, the customers, or trigger compliance obligations.

6.7 Control Effectiveness Guide

Effectiveness	Interpretation
0%	No effective control exists or the control has not been implemented.
25%	Controls are weak, informal, manual, inconsistently performed, or largely unevidenced.
50%	Controls are partially effective but have material design, implementation, or operating gaps.
75%	Controls are generally effective with minor gaps or limited improvement opportunities.
100%	Controls are fully implemented, consistently operating, evidenced, tested, and effective.

6.8 Risk Treatment Guide

Treatment	Use When
Mitigate	Additional controls, remediation, or improvement actions are required to reduce the residual risk.
Accept	Residual risk is within the approved risk appetite or is approved by the appropriate authority with documented rationale.
Transfer	A portion of the risk is shifted to another party, such as through insurance, contractual obligation, or outsourced service arrangement.
Avoid	The activity, system, or process causing the risk is discontinued or not pursued.

6.9 Scoring and Formula Guidance

The template uses formula-driven scoring to promote consistency and reduce manual calculation errors.

- Inherent Risk Score = Inherent Likelihood x Inherent Impact
- Residual Risk Score = Residual Likelihood x Residual Impact

Control Effectiveness shall be selected from the prescribed ratings of **0%, 25%, 50%, 75%, or 100%**, based on the assessed design, implementation, and operating effectiveness of the applicable controls.

When adding new risks, copy the applicable formulas from the preceding row, ensure that Control Effectiveness is formatted as a percentage, and validate that the calculated scores reasonably reflect the effectiveness of the applicable controls.

6.10 Quality Review Checklist

Review Area	Validation Question
Completeness	Are all required Risk Register columns completed?
Risk Description	Is the risk specific, understandable, and written as a clear threat event with consequence?

Information Security Risk Assessment Procedure TCH-CYB-W005

Likelihood and Impact	Are ratings supported by the Rating Guidance worksheet and available evidence?
Existing Controls	Are only implemented and relevant controls listed?
Control Effectiveness	Is the percentage reasonable, evidence-based, and aligned with the maturity of the controls?
Formula Fields	Are Inherent Risk Score and Residual Risk Score automatically calculated and not manually overwritten?
Risk Treatment	Is the treatment decision appropriate based on residual risk?
Action Plan	For risks marked as Treat, is there a specific action plan, owner, and commitment date?
Approval	For accepted risks, is the approval and rationale documented?

6.11 Documentation and Evidence Requirements

Where applicable, retain evidence supporting the risk assessment, including but not limited to:

- System screenshots or configuration evidence
- Access review records
- Incident records or near-miss reports
- Vulnerability assessment or penetration test results
- Change tickets and approval records
- Backup and restoration test results
- Security monitoring alerts or SIEM records
- Policy, standard, or procedure references
- Vendor due diligence or third-party assessment records
- Risk acceptance approvals and management sign-offs

7. Reporting

The Information Security Team shall maintain completed ISRA outputs and may provide periodic reporting to relevant management, risk, compliance, audit, or governance forums as applicable. Reports may include the number of assessed risks, high residual risks, overdue action plans, accepted risks, recurring control gaps, and remediation progress. Reporting frequency shall be aligned with

Information Security Risk Assessment Procedure TCH-CYB-W005

management requirements, risk governance cadence, or applicable regulatory and audit expectations.

8. Exception Handling and Escalation

Exceptions to this procedure, including deviations from the required template fields, rating methodology, documentation requirements, or remediation timelines, must be documented with business rationale and approved by the Management Committee. Risks with high residual exposure, overdue remediation, disputed risk ratings, or proposed risk acceptance outside normal appetite shall be escalated to the Risk Owner, Information Security leadership, and other relevant governance bodies as applicable.

9. Violations

Failure to comply with this procedure may result in incomplete or inaccurate risk assessment outputs, delayed remediation, or unmanaged information security exposure. Non-compliance may be escalated to the relevant management function and handled in accordance with applicable company policies, procedures, and employee conduct requirements.

10. Transitory Period and Implementation

This procedure shall take effect upon approval unless a separate implementation date is defined by management. The Cybersecurity Team shall communicate the procedure to affected stakeholders and provide orientation or guidance as necessary to ensure consistent completion of the ISRA Template. Existing assessments may be aligned with this procedure during the next scheduled review cycle or earlier when a material change, incident, finding, or management request requires reassessment.

11. Appendix

Appendix 11.1 Sample Completed Risk Register Entry

Field	Example
ID	R-01
Process	Cloud Storage
Risk Description	Ransomware encryption of backup files may result in inability to restore critical systems during a security incident.
Inherent Likelihood (1–5)	4
Inherent Impact (1–5)	5
Inherent Risk Score	20
Existing Controls	Daily air-gapped backups, immutable storage, and endpoint detection and response.

Information Security Risk Assessment Procedure TCH-CYB-W005

Control Effectiveness (0–100%)	75%
Control Effectiveness Remarks	Controls are generally effective with minor gaps or limited improvement opportunities.
Residual Likelihood	2
Residual Impact	3
Residual Risk Score	6
Risk Treatment	Mitigate
Action Plan / Owner	Security Team to audit immutable backup configuration and validate backup restoration testing results.
Commitment Date	To be provided by the action owner.
Evidence Link	

Appendix 11.2 References

- Enterprise Information Security Policy
- Enterprise Risk Management Policy
- Information Security Policy
- IMTPP

Appendix 11.3 RACI Matrix

Process Activity	Cybersecurity Team	Risk Owner / Process Owner	Control Owner	Action Owner	Head of DevSecOps
Identify and validate risk scenarios	A/R	R	C	C	I
Assess inherent risk	A/R	C	C	I	I
Identify and assess existing controls	A/R	C	R	C	I
Determine residual risk and treatment option	A/R	R	C	C	C
Develop and assign treatment actions	A/R	R	C	R	C

Information Security Risk Assessment Procedure TCH-CYB-W005

Review the ISRA	R	C	C	I	A
Approve the ISRA	C	C	C	I	R
Monitor, validate, and close actions	A/R	C	C	R	I
Escalate, report, maintain, and reassess	A/R	C	C	I	I

12. Review and Approval

Prepared By:	Approved By:
Royette Miranda Manager, Cybersecurity Governance	Franz Allan See Chief Technology Officer
Reviewed By:	
Jan Almazora Head of DevSecOps Annibelle Siao Head of Risk Management Atty. Ralph Deric Espiritu Senior officer, Legal	

--	--

13. Document History

Version	v1
Executive Summary:	This procedure establishes a standardized, evidence-based approach for identifying, assessing, treating, documenting, approving, and monitoring information security risks affecting PDAX systems, applications, processes, infrastructure, data, and third-party services. It defines the end-to-end ISRA process, roles and responsibilities, 5x5 risk-rating methodology, control effectiveness and residual risk calculations, treatment requirements, and governance expectations to ensure risks are consistently managed throughout their lifecycle.
Date Approved	<Date approved in Board or Mancom (January 1, 2026) >
Author	R. Miranda
Changes History	Initial release